AUDITORÍA ISO 27001

GRC Corporativo

0. Control de Cambios

Versión	Fecha	Descripción	Responsable
1.0	Marzo 2026	Versión inicial del informe de auditoría interna ISO 27001:2013.	Pepita Pérez

ÍNDICE

	Página
0. Control de cambios	**1**
1. Introducción	**3**
1.1 Alcance de la auditoría	
1.2 Documentación revisada	
1.3 Metodología	
1.4 Contexto de la organización	
2. Parte I — Requisitos obligatorios ISO 27001:2013	**6**
2.1 Requisito 4.1 — Contexto de la organización	
2.2 Requisito 8.3 — Tratamiento de riesgos	
2.3 Requisito 9.1 — Seguimiento y medición	
2.4 Requisito 9.2 — Auditorías internas	
3. Parte II — Controles del Anexo A (ISO/IEC 27002:2013)	**15**
3.1 A5.1.1 — Políticas para la seguridad	
3.2 A9.4.3 — Gestión de contraseñas	
3.3 A10.1.1 — Controles criptográficos	
3.4 A11.1.3 — Seguridad física de oficinas	
3.5 A12.4.1 — Registro de eventos de actividad	
3.6 A13.1.3 — Segregación en redes	
3.7 A17.1.1 — Continuidad de la seguridad	
3.8 A18.1.2 — Derechos de Propiedad Intelectual	
4. Resumen de hallazgos	**32**
5. Conclusiones y recomendaciones	**34**
Anexo. Plantilla de controles y plantilla de SOA. Documento Excel	

1. Introducción

XYZ S.L. es una empresa mediana del sector logístico, con aproximadamente 60 empleados, cuya operativa diaria depende de forma estructural del ERP SAP Business One (v10.0). No es una dependencia teórica: en octubre del año pasado, un corte eléctrico de cuatro horas dejó a los repartidores coordinándose por teléfono y a administración sin poder emitir albaranes ni consultar estados de pedido. El incidente no llegó a ser una crisis solo porque duró poco. Esa conversación fue, según el propio CEO, uno de los motivos concretos de activar el proceso hacia la certificación ISO 27001.

La nueva gerencia ha impulsado en menos de dos años un conjunto de documentos formales: unas políticas de seguridad aprobadas, un análisis de riesgos metodológicamente sólido bajo ISO 27005, ISO 31000 y MAGERIT v3, un Plan Director de Seguridad con horizonte 2026-2028 y un Plan de Respuesta ante Incidentes. Es un punto de partida real. El problema, como veremos, no es lo que está escrito, sino la distancia entre lo escrito y lo que ocurre cada día.

El objetivo de esta auditoría no es señalar fallos por señalarlos. Es identificar con precisión qué está funcionando, qué está en camino y qué debe resolverse antes de que un auditor de certificación llegue. Lo que sigue es el resultado de dos días de trabajo: revisión documental, entrevistas con Marta López (CISO) y Juan Pérez (Responsable IT) e inspección técnica y física de las instalaciones los días 3 y 4 de marzo de 2026.

1.1 Alcance de la auditoría

El alcance del SGSI auditado abarca todas las áreas vinculadas a la prestación del servicio logístico de XYZ S.L.: envío, recepción y almacenamiento de paquetería. En términos prácticos, esto incluye:

- Infraestructura tecnológica: CPD local con servidor HP ProLiant DL380 Gen9 (seis años en producción, soporte de firmware expirado desde 2023), servidor Active Directory, ERP SAP Business One, NAS de almacenamiento con síntomas físicos de degradación, SAI con batería degradada sin sustitución programada, y red corporativa con controlador Wi-Fi.
- Servicios en la nube: Microsoft 365 (correo Exchange y servidor de ficheros), solución de backup cloud.
- Dispositivos de usuario: portátiles corporativos (~60 unidades) y dispositivos móviles asignados al personal que teletrabaja.
- Modalidades de trabajo: presencial en sede y teletrabajo.

- Ubicaciones: sede principal en edificio de alquiler en España, con servicio de seguridad privada gestionado por el propietario del inmueble.

1.2 Documentación revisada

Durante la auditoría se revisaron los siguientes documentos:

- PSI_XYZ_v1.1_May2024.docx — Políticas de Seguridad de la Información (Política I y Política II), aprobadas por Gerencia General.
- Informe_AR_XYZ_v1.0_Mar2026.docx — Informe de Análisis de Riesgos (ISO 27005 / MAGERIT v3), 15 escenarios, 35 páginas.
- PDS_XYZ_v1.0.docx — Plan Director de Seguridad 2026-2028, con hallazgos O1-O8 y T1-T2.
- PRI_XYZ_v1.0_Mar2026.docx — Plan de Respuesta ante Incidentes, v1.0.
- PA_XYZ_2026.xlsx — Plan de Acción de Seguridad con proyectos, responsables y plazos.
- ISO27k_ISMS_controls_status_Spanish.xlsx — Plantilla de auditoría ISO27k (pestañas 'Req. Obligatorios SGSI', 'Controles Anexo A' y 'Métricas').

1.3 Metodología

La auditoría sigue los pasos definidos en el apartado 2.1.3 de la guía de auditoría ISO 27001. Para cada control se aplica el mismo proceso: comprensión del control (qué exige la norma), evaluación con evidencias (qué tiene XYZ S.L. y cómo funciona en la práctica), y conclusión con clasificación del hallazgo según la escala estándar:

- No conformidad mayor: incumplimiento de un requisito obligatorio que impediría directamente la certificación.
- No conformidad menor: incumplimiento parcial o deficiencia subsanable en un plazo razonable.
- Observación: aspecto que funciona pero que conviene reforzar o documentar antes de la certificación.
- Oportunidad de mejora: recomendación que va más allá de lo estrictamente exigido.

A cada control se asigna un nivel de madurez conforme a la escala de la plantilla ISO27k: Inexistente / Inicial / Repetible / Definido / Administrado / Optimizado. Las técnicas utilizadas han sido revisión documental, entrevistas semiestructuradas, inspección técnica mediante muestreo de equipos y configuraciones, e inspección física de las instalaciones.

1.4 Contexto de la organización

XYZ S.L. gestiona datos identificativos y de contacto de aproximadamente 3.200 clientes activos, sujetos al RGPD y a la LOPDGDD. Una brecha de seguridad podría implicar sanciones de hasta el 4% de la facturación anual, obligación de notificación a la AEPD en menos de 72 horas, y un daño reputacional difícil de reparar en un sector donde la confianza es el principal activo comercial.

La infraestructura es híbrida: CPD local con dependencia alta del ERP y servicios cloud para correo, backups y gestión documental. Con solo dos personas gestionando toda la infraestructura crítica (Marcos, administrador de sistemas, y Ana, soporte técnico), la concentración de conocimiento técnico es en sí misma un factor de riesgo que aparece de forma recurrente a lo largo de este informe. El PDS lo reconoció explícitamente como hallazgo O2.

2. Parte I — Requisitos obligatorios ISO 27001:2013

Los requisitos de los capítulos 4 al 10 de ISO 27001 no son opcionales. Todos deben estar implantados y evidenciados para que el SGSI sea certificable. Lo que se audita aquí no es si XYZ S.L. tiene buenas intenciones, sino si puede demostrar con evidencias documentales que los procesos existen, funcionan y se mantienen.

2.1 Requisito 4.1 — Comprensión de la organización y de su contexto

a) Comprensión del control

La cláusula 4.1 de ISO 27001 exige que la organización determine los factores externos e internos relevantes para su propósito que puedan afectar a los resultados del SGSI. Pero el contexto no es solo 'qué hace la empresa': la norma exige identificar formalmente a todas las partes interesadas (clientes, empleados, proveedores, reguladores) y documentar sus requisitos de seguridad. Exige también que el RGPD y otras obligaciones legales se integren como factores de contexto externo con impacto directo en el diseño del SGSI, no como referencias pasajeras en un pie de página.

Las preguntas de verificación clave son:

- ¿Se han determinado formalmente los factores internos y externos que afectan al SGSI mediante un análisis estructurado (DAFO, PESTEL u equivalente)?
- ¿Se han identificado todas las partes interesadas relevantes —clientes, empleados, proveedores estratégicos, organismos reguladores— y sus requisitos de seguridad específicos?
- ¿Está el RGPD integrado como factor de contexto externo crítico, con sus implicaciones para el diseño del SGSI documentadas?
- ¿Los contratos con proveedores incluyen cláusulas de seguridad de la información derivadas del análisis de partes interesadas?

b) Evaluación y evidencias

Lo que tiene XYZ S.L. es mejor de lo que cabría esperar en una organización de este tamaño que acaba de arrancar su SGSI. El Informe_AR_XYZ_v1.0_Mar2026.docx contiene, en su sección 2.2, un análisis de contexto interno detallado y honesto: la dependencia estructural del ERP, la infraestructura híbrida, la concentración operativa en Marcos y Ana, y las vulnerabilidades técnicas conocidas y no resueltas. El SAI con la alarma de batería que 'aguanta hasta el verano'. El NAS con el

ruido extraño que Marcos cree que es un disco pero que aún no ha podido revisar. El hipervisor sin parchear tres meses por miedo al downtime. Las reglas del FortiGate 60F sin auditar desde 2022. Es un diagnóstico honesto.

El problema técnico es que todo esto está integrado dentro del Análisis de Riesgos, no existe como documento formal e independiente de contexto organizativo. Un auditor de certificación buscará un artefacto concreto que evidencie el análisis del contexto. Encontrarlo embebido en otro informe es posible, pero genera debates innecesarios.

Más importante: el análisis de partes interesadas está incompleto de forma técnicamente significativa. El Informe_AR_XYZ menciona el RGPD y la LOPDGDD de forma genérica, pero no los integra como factores de contexto externo que determinan requisitos concretos del SGSI: notificación a la AEPD en 72 horas ante brecha, designación de DPO si aplica, registro de actividades de tratamiento. Los 3.200 clientes activos cuya información gestiona XYZ S.L. son una parte interesada de primera categoría cuyos requisitos de seguridad no están documentados formalmente. Los proveedores estratégicos —proveedor SaaS, Microsoft como proveedor de 365, empresa de seguridad del edificio— no aparecen en ningún registro formal de partes interesadas con sus requisitos asociados. La revisión de los contratos en vigor lo confirma: el contrato con el proveedor SaaS, que llevaba meses pendiente de revisión con renovación prevista en marzo, no incluye ninguna cláusula sobre protección de datos ni continuidad del servicio.

Control auditado	4.1 — Comprensión de la organización y de su contexto
Evidencias revisadas	Informe_AR_XYZ_v1.0_Mar2026.docx (sección 2.2 — contexto interno y externo); PDS_XYZ_v1.0.docx; PSI_XYZ_v1.1_May2024.docx; contratos con proveedor SaaS y empresa de seguridad del edificio (sin cláusulas de seguridad)
Técnicas de verificación	Revisión documental, entrevistas con Marta López (CISO) y Juan Pérez (IT), muestreo de contratos con proveedores externos, verificación de referencias normativas al RGPD en la documentación del SGSI

Nivel de madurez **Inicial**	El análisis de contexto interno existe con buena profundidad dentro del Informe_AR_XYZ, pero no está formalizado como documento independiente. La identificación de partes interesadas —clientes (3.200 activos sujetos a RGPD), empleados, proveedores estratégicos, AEPD— es incompleta. El RGPD no está integrado como factor de contexto externo con implicaciones concretas para el SGSI. Contratos de proveedores sin cláusulas de seguridad.

c) Conclusiones

NC MENOR NC-R-01	La organización carece de un documento formal de contexto organizativo independiente. El análisis de partes interesadas no identifica a los clientes (3.200 activos, sujetos a RGPD), a los empleados como parte interesada con requisitos propios, ni a los proveedores estratégicos (proveedor SaaS, Microsoft 365, empresa de seguridad del edificio) con sus requisitos de seguridad asociados. El RGPD no está integrado como factor de contexto externo crítico que determine requisitos del SGSI. Los contratos de proveedores revisados carecen de cláusulas de seguridad de la información. Acción correctiva: Marta López (CISO) debe elaborar un documento formal de contexto organizativo (estructura DAFO + partes interesadas + requisitos de seguridad), integrar el RGPD como factor externo con sus implicaciones concretas (72h AEPD, ROPA, etc.) y coordinar con Legal la inclusión de cláusulas de seguridad en los contratos de proveedores en la próxima renovación.

2.2 Requisito 8.3 — Tratamiento de los riesgos de seguridad de la información

a) Comprensión del control

La cláusula 8.3 exige que la organización implemente el plan de tratamiento de riesgos, documente los resultados y obtenga la aprobación formal de los propietarios del riesgo —no del equipo técnico— sobre el riesgo residual aceptado. Sin este cierre formal, el ciclo de gestión del riesgo queda

incompleto: se han identificado y evaluado los riesgos, pero nadie con autoridad ha decidido formalmente qué hacer con ellos.

- ¿Se ha implementado el plan de tratamiento con resultados documentados para los 15 escenarios identificados?
- ¿Han aprobado formalmente los propietarios del riesgo el plan y el riesgo residual, mediante acta o documento equivalente?
- ¿Existe decisión documentada para todos los escenarios, incluyendo los de nivel bajo?

b) Evaluación y evidencias

El Informe_AR_XYZ_v1.0_Mar2026.docx es, sin duda, el documento más sólido del conjunto. Los 15 escenarios de riesgo están desarrollados con metodología semicuantitativa coherente (ISO 27005 / MAGERIT v3), con probabilidad, impacto, riesgo inherente, controles existentes, opción de tratamiento y riesgo residual. El escenario R2 (ransomware sobre la base de datos ERP, nivel 15, inaceptable) y el R9 (filtración de datos de los 3.200 clientes, nivel 15, inaceptable) están especialmente bien desarrollados, con rutas de materialización realistas y medidas de mitigación concretas. El PA_XYZ_2026.xlsx recoge los proyectos derivados con responsable, plazo y coste estimado.

Lo que falta es el cierre formal. No existe ninguna acta de reunión del Comité de Dirección que recoja la revisión del análisis y la aprobación del plan de tratamiento. No hay firma de los propietarios de riesgo designados sobre el riesgo residual. Cuando se le planteó esta cuestión a Marta López durante la entrevista, su respuesta fue que 'la Dirección está al corriente del análisis y lo apoya'. Ese apoyo implícito no es evidencia suficiente para una auditoría de certificación.

Para tres de los quince escenarios de nivel bajo (R11, R13, R15), la documentación registra el riesgo residual sin indicar quién toma la decisión de aceptarlo ni con qué justificación. En una auditoría de certificación, la pregunta '¿quién aprobó esto y cuándo?' necesita respuesta documental concreta.

Control auditado	8.3 — Tratamiento de los riesgos de seguridad de la información
Evidencias revisadas	Informe_AR_XYZ_v1.0_Mar2026.docx (sección 8 — plan de tratamiento); PA_XYZ_2026.xlsx; búsqueda de Acta_Comite_Seguridad sin resultado

Técnicas de verificación	Revisión del informe de riesgos, verificación de actas de aprobación formal por Comité de Dirección, comprobación de cobertura de escenarios de nivel bajo

Nivel de madurez **Definido**	Plan de tratamiento bien documentado y metodológicamente riguroso para los 15 escenarios. Pendiente de aprobación formal por la Dirección y los propietarios de riesgo. Tres escenarios de nivel bajo sin decisión de aceptación documentada.

c) Conclusiones

NC MENOR NC-R-02	El plan de tratamiento de riesgos está bien desarrollado técnicamente y es coherente con el Plan de Acción, pero no existe evidencia de aprobación formal por el Comité de Dirección ni de aceptación documentada del riesgo residual por los propietarios de riesgo designados. La ausencia de Acta_Comite_Seguridad que recoja esta aprobación es determinante. Para tres escenarios de nivel bajo (R11, R13, R15) no consta la decisión de aceptación. Acción correctiva: Juan Pérez (IT) debe convocar reunión de revisión con el Comité de Dirección, generar el acta con la aprobación explícita del plan de tratamiento y la aceptación del riesgo residual, y completar la documentación de los escenarios de nivel bajo con la decisión y su justificación. Plazo recomendado: 60 días.

2.3 Requisito 9.1 — Seguimiento, medición, análisis y evaluación

a) Comprensión del control

La cláusula 9.1 exige que la organización evalúe el desempeño de la seguridad de la información y la eficacia del SGSI de forma sistemática: determinando qué medir, cómo, con qué frecuencia, quién lo hace y conservando evidencia documentada de los resultados. Sin un sistema de métricas operativo, el SGSI es una colección de documentos que no sabe si funciona. Este es el requisito que con más

frecuencia bloquea las certificaciones de organizaciones que tienen buena documentación pero no han cerrado el ciclo de gestión.

- ¿Existe un sistema de métricas e indicadores definido, operativo y con proceso de medición implantado?
- ¿Se realizan mediciones periódicas con resultados documentados y analizados?
- ¿Hay un cuadro de mando del SGSI o equivalente que permita evaluar la eficacia de los controles?

b) Evaluación y evidencias

Las PSI_XYZ_v1.1_May2024.docx definen cuatro KPIs en su sección de métricas: KPI-01 (porcentaje de empleados con MFA activo, objetivo 100%), KPI-02 (tiempo de revocación de credenciales tras baja, objetivo < 2 horas), KPI-03 (porcentaje de dispositivos con borrado remoto exitoso) y KPI-04 (tasa de éxito en simulacros de phishing, objetivo < 5% de clics). Que estos indicadores existan por escrito en las políticas formales es, en sí mismo, un avance positivo.

Pero durante la entrevista con Marta López quedó meridianamente claro que ninguno de estos KPIs se está midiendo de forma sistemática. La respuesta fue directa: 'los definimos como objetivo, el sistema de recogida todavía no está montado'. No existe ningún informe de métricas del SGSI. No hay cuadro de mando. No hay proceso que establezca periodicidad, fuente de datos, responsable ni umbral de alerta. Cuando se solicitó cualquier registro histórico de mediciones, la respuesta fue que no existe. La pestaña 'Métricas' de la ISO27k_ISMS_controls_status_Spanish.xlsx —que debería ser la herramienta de seguimiento— muestra todos los controles en estado '? Desconocido', lo cual no es una sorpresa: es el reflejo fiel de la situación real.

La consecuencia práctica es que XYZ S.L. no puede responder a la pregunta más básica de cualquier SGSI: ¿están funcionando los controles que hemos implantado? ¿Está activo el MFA en todos los equipos? ¿Se revocaron las credenciales de los empleados que causaron baja dentro del plazo establecido? No se sabe. Y no saberlo, en una auditoría de certificación, es un bloqueo directo.

Control auditado	9.1 — Seguimiento, medición, análisis y evaluación
Evidencias revisadas	PSI_XYZ_v1.1_May2024.docx (sección KPIs); ISO27k_ISMS_controls_status_Spanish.xlsx (pestaña Métricas — todos en estado desconocido); entrevista con Marta López (CISO)

Técnicas de verificación	Solicitud de informes de métricas históricos, entrevista sobre el proceso de medición implantado, revisión de la pestaña Métricas en plantilla Excel

Nivel de madurez **Inicial**	Cuatro KPIs definidos formalmente en las políticas, pero sin sistema operativo de medición, sin proceso de recogida de datos, sin registro de resultados y sin cuadro de mando. El proceso de evaluación del desempeño del SGSI no existe en la práctica.

c) Conclusiones

NC MAYOR NC-R-03 · NO CONFORMIDAD MAYOR	XYZ S.L. no dispone de ningún sistema operativo de seguimiento, medición, análisis y evaluación del SGSI. Los cuatro KPIs existen en papel pero no se miden, no se registran y no se analizan. Este es un requisito obligatorio cuyo incumplimiento es, por sí solo, causa directa de denegación de la certificación: sin métricas, no es posible demostrar la eficacia del SGSI. Acción correctiva inmediata: Marta López (CISO) debe diseñar e implantar el sistema de métricas del SGSI antes de la auditoría de certificación, estableciendo para cada KPI la fuente de datos, el responsable de medición, la frecuencia (mensual recomendado), el método de cálculo y el umbral de alerta. Los resultados deben quedar registrados y ser revisados en reuniones de Comité de Dirección con periodicidad mínima semestral. Plazo máximo: 90 días.

2.4 Requisito 9.2 — Auditorías internas

a) Comprensión del control

La cláusula 9.2 exige un programa de auditoría interna planificado y programado, aprobado formalmente por la dirección, con criterios de auditoría definidos, alcance documentado, auditores con independencia respecto al área auditada, y conservación de evidencia de los resultados. No basta

con hacer revisiones técnicas informales ni con que la dirección 'sepa lo que pasa'. El programa anual firmado por la dirección es el artefacto clave que demuestra que el proceso de auditoría interna existe y está gobernado.

- ¿Existe un Programa Anual de Auditoría Interna del SGSI, documentado y aprobado formalmente por la dirección?
- ¿Se conserva documentación del programa y de los resultados de cada ciclo de auditoría?
- ¿Los auditores ejecutan las auditorías con independencia real del área auditada?

b) Evaluación y evidencias

Se solicitó el Programa Anual de Auditoría Interna del SGSI. No existe. El PDS_XYZ_v1.0.docx contempla revisiones técnicas periódicas (hardening, parcheo, gestión de accesos), pero estas actividades técnicas no constituyen una auditoría interna del SGSI en el sentido de la norma: no tienen criterios de auditoría formalmente definidos, no cubren el alcance completo del SGSI y no son ejecutadas por auditores independientes del área auditada. Marcos no puede auditar la infraestructura que él mismo gestiona.

Lo que resulta preocupante no es solo la ausencia del programa, sino la confusión conceptual que se detectó en la entrevista. El CISO mencionó el Informe_AR_XYZ como una posible 'auditoría de seguridad'. Hay una cierta lógica en esa idea, y el análisis de riesgos tiene, en efecto, una calidad técnica que supera a lo que se ve en muchas organizaciones similares. Pero no es una auditoría interna del SGSI: no tiene estructura de auditoría, no genera hallazgos clasificados conforme a la norma, no fue ejecutada con independencia formal del equipo auditado y no cubre todos los controles del SGSI.

La presente auditoría es, de hecho, la primera que se realiza formalmente en XYZ S.L. Eso convierte este hallazgo en una no conformidad menor —no mayor—, porque la norma permite que la primera auditoría interna sea la de preparación para certificación. Pero la ausencia de un Programa Anual aprobado por la dirección, que planifique los ciclos futuros, no puede prolongarse más allá de esta fase.

Control auditado	9.2 — Auditorías internas

Evidencias revisadas	PDS_XYZ_v1.0.docx; Informe_AR_XYZ_v1.0_Mar2026.docx; entrevista con Marta López (CISO); búsqueda de Programa_Auditoria_Interna_2026.docx sin resultado
Técnicas de verificación	Solicitud del Programa Anual de Auditoría Interna, revisión de informes de auditorías previas, entrevista sobre planificación de ciclos futuros

Nivel de madurez **Inexistente**	No existe Programa Anual de Auditoría Interna del SGSI aprobado por la dirección. Las revisiones técnicas realizadas no cumplen los requisitos de independencia, criterios formales, alcance SGSI y documentación de resultados exigidos por la norma.

c) Conclusiones

NC MENOR NC-R-04	No existe Programa Anual de Auditoría Interna del SGSI aprobado formalmente por la dirección. La presente auditoría es la primera realizada con metodología ISO 27001. Las revisiones técnicas periódicas recogidas en el PDS no son equivalentes a una auditoría interna del SGSI. Acción correctiva: Marta López (CISO) debe elaborar el Programa Anual de Auditoría Interna 2026-2027 y someterlo a aprobación formal de Gerencia antes de la auditoría de certificación. El programa debe definir criterios, alcance, frecuencia, métodos y auditores con independencia acreditada. Si en 12 meses no se ha ejecutado al menos un ciclo completo con su informe, esta no conformidad escalará a mayor.

3. Parte II — Controles del Anexo A (ISO/IEC 27002:2013)

Los controles del Anexo A no son todos obligatorios por definición, pero sí lo son todos aquellos que XYZ S.L. ha declarado aplicables. Lo que se evalúa aquí es si los controles seleccionados están implantados, documentados y —lo más importante— funcionan en la práctica cotidiana. La diferencia entre tener un control escrito en una política y tener evidencia de que ese control se aplica a las seis de la tarde de un martes cualquiera es exactamente lo que distingue un SGSI real de uno en papel.

3.1 Control A5.1.1 — Políticas para la seguridad de la información

a) Comprensión del control

ISO 27002 exige que las políticas de seguridad sean definidas, aprobadas por la dirección, publicadas y comunicadas a todos los empleados y partes externas pertinentes. Las políticas deben ser revisadas periódicamente o cuando se produzcan cambios significativos.

- ¿Existe un cuerpo normativo completo, coherente con los riesgos identificados y aprobado formalmente por la dirección?
- ¿Hay evidencia documental de que todos los empleados han recibido y aceptado las políticas?
- ¿La revisión anual prevista está documentada como completada?

b) Evaluación y evidencias

XYZ S.L. dispone de las PSI_XYZ_v1.1_May2024.docx: dos políticas principales aprobadas formalmente por Gerencia General con acta de aprobación firmada. La Política I cubre control de acceso y seguridad en el teletrabajo; la Política II, uso de activos y correo electrónico. El contenido es apropiado para el contexto: mínimo privilegio, MFA obligatorio, VPN para acceso remoto, BitLocker en dispositivos, clear desk, prohibición de software no autorizado. Las políticas incluyen checklists de cumplimiento y los KPIs referenciados en la cláusula 9.1. Es un documento bien estructurado y técnicamente coherente con los riesgos identificados en el Informe_AR_XYZ.

Hay dos puntos que necesitan atención antes de la certificación. El primero: no se pudo presentar ningún registro documental de que todos los empleados hayan firmado la aceptación de las políticas. El CISO explicó que la comunicación se realizó en reunión de equipo y por correo electrónico. 'Lo comunicamos a todos en la reunión de mayo' no es evidencia suficiente para un auditor externo; lo

que necesita ver es un registro con nombre, fecha y firma —electrónica o física. El segundo: la revisión anual prevista para mayo de 2025 no está documentada como completada en ningún artefacto de la documentación revisada.

Control auditado	A5.1.1 — Políticas para la seguridad de la información
Evidencias revisadas	PSI_XYZ_v1.1_May2024.docx; acta de aprobación de Gerencia General (disponible); registro de firmas de empleados (no disponible); evidencia de revisión mayo 2025 (no disponible)
Técnicas de verificación	Revisión del contenido y estructura de las políticas, solicitud del registro de aceptación de empleados, verificación del estado de la revisión anual

Nivel de madurez **Administrado**	Políticas aprobadas formalmente por la dirección, con estructura adecuada y cobertura de los controles principales. Falta evidencia documental de aceptación por todos los empleados y la revisión anual 2025 no está documentada.

c) Conclusiones

CONFORME CONF-A-01	Las políticas de seguridad de XYZ S.L. están aprobadas formalmente por Gerencia General, tienen estructura adecuada y cubren los activos y riesgos principales identificados en el análisis de riesgos. El control A5.1.1 se considera conforme.

OBSERVACION OBS-A-01	No existe registro documental de aceptación formal de las políticas por parte de todos los empleados. La revisión anual prevista para mayo de 2025 no está documentada. Se recomienda implantar un proceso de firma de aceptación electrónica antes de la auditoría de certificación y registrar el resultado de la

	revisión anual en un documento de control. Si no se subsana, derivará en no conformidad menor.

3.2 Control A9.4.3 — Sistema de gestión de contraseñas de usuario

a) Comprensión del control

ISO 27002 exige que los sistemas de gestión de contraseñas garanticen calidad suficiente: longitud mínima, complejidad, historial que impida reutilización, expiración forzada periódica, cambio obligatorio en el primer inicio de sesión, y almacenamiento y transmisión seguros. La evidencia técnica clave es la configuración de las GPOs (Group Policy Objects) del Active Directory, que son las que determinan si los requisitos de las políticas escritas se aplican de forma técnica y automática sobre todos los usuarios —no solo en teoría.

- ¿Las GPOs del Active Directory están configuradas para forzar longitud mínima, complejidad, historial de contraseñas (≥5) y expiración periódica (≤90 días)?
- ¿El procedimiento de entrega de credenciales iniciales a nuevos usuarios está documentado y fuerza cambio en el primer inicio de sesión?
- ¿Los usuarios cumplen en la práctica con la política de no anotar contraseñas ni compartirlas por canales inseguros?

b) Evaluación y evidencias

Las PSI_XYZ_v1.1_May2024.docx exigen contraseñas de mínimo 12 caracteres con complejidad (mayúsculas, minúsculas, números y símbolos) y prohíben explícitamente anotarlas en post-its o transmitirlas por correo electrónico. La GPO de contraseñas del Active Directory tiene configurados los requisitos básicos de longitud y complejidad. Hasta ahí, coherencia entre la norma escrita y la implementación técnica.

La inspección física de tres puestos de trabajo seleccionados al azar —mesa de Juan Pérez incluida— encontró contraseñas anotadas en post-its en dos de ellos: uno adherido al monitor y otro debajo del teclado, visible al levantar el periférico. La GPO del AD no tiene configurado historial de contraseñas (que impediría reutilizar las mismas cinco anteriores) ni expiración forzada periódica de 90 días: ambos parámetros estaban en blanco en la captura de configuración obtenida durante la auditoría. Dos de los cinco usuarios entrevistados reconocieron enviar contraseñas de aplicaciones

corporativas por correo electrónico o WhatsApp cuando un compañero olvida la suya. 'Nunca ha pasado nada' fue la justificación recurrente. El procedimiento de entrega de credenciales iniciales a nuevas incorporaciones es completamente verbal entre Marcos y el nuevo usuario, sin registro de entrega ni flag técnico que fuerce el cambio de contraseña en el primer inicio de sesión.

Control auditado	A9.4.3 — Sistema de gestión de contraseñas de usuario
Evidencias revisadas	PSI_XYZ_v1.1_May2024.docx; captura de configuración de GPO de contraseñas del AD (sin historial, sin expiración forzada); inspección física de 3 puestos de trabajo (muestreo); entrevistas a 5 usuarios; revisión del procedimiento de onboarding
Técnicas de verificación	Revisión de la configuración de GPOs del Active Directory, inspección física de puestos de trabajo, entrevistas con usuarios finales, solicitud del procedimiento de gestión de credenciales en altas

Nivel de madurez **Inicial**	Requisitos básicos en política escrita y GPO de longitud/complejidad configurada. Sin embargo, ausencia de historial de contraseñas y expiración forzada en GPO. Contraseñas en post-its y compartición por correo confirmadas. Procedimiento de alta informal y sin registro.

c) Conclusiones

NC MENOR NC-A-01	Las GPOs del Active Directory no tienen configurado historial de contraseñas (parámetro en blanco: reutilización inmediata posible) ni expiración forzada de 90 días. Se detectaron contraseñas anotadas en post-its en 2 de los 3 puestos inspeccionados. Dos usuarios confirmaron compartir contraseñas por correo electrónico. El procedimiento de entrega de credenciales iniciales es verbal y sin registro. Acciones correctivas: (1) Juan Pérez debe configurar las GPOs del AD para incluir historial mínimo de 5 contraseñas y expiración forzada de 90 días — plazo: 15 días. (2) Marta López debe organizar sesión de concienciación urgente sobre gestión de contraseñas. (3) Documentar y

	formalizar el procedimiento de onboarding de credenciales con flag de cambio obligatorio en primer acceso. (4) Evaluar e implantar un gestor de contraseñas corporativo.

3.3 Control A10.1.1 — Política de uso de los controles criptográficos

a) Comprensión del control

ISO 27002 exige una política formal de uso de controles criptográficos que defina: cuándo es obligatorio cifrar, qué algoritmos y protocolos mínimos son aceptables, cómo se gestiona el ciclo de vida de las claves (generación, distribución, almacenamiento, revocación) y cómo se garantiza el cumplimiento del marco legal. El cifrado sin política es un control técnico sin gobierno: nadie sabe exactamente qué se cifra, con qué algoritmo, ni qué ocurre con las claves cuando un empleado causa baja.

- ¿Existe un documento formal de política de controles criptográficos con casos de aplicación obligatoria, algoritmos mínimos y proceso de gestión de claves?
- ¿Se ha verificado que el cifrado de dispositivos (BitLocker) está activo en todos los portátiles, incluidos los de los teletrabajadores?
- ¿Las claves de recuperación de BitLocker están almacenadas con controles de acceso adecuados?

b) Evaluación y evidencias

XYZ S.L. aplica cifrado de forma práctica en varios puntos: BitLocker obligatorio en portátiles según las políticas, VPN cifrada para el teletrabajo, y verificación de BitLocker en el checklist de cumplimiento. Son medidas apropiadas para el contexto.

Lo que resulta preocupante es doble. Primero, no existe política formal de controles criptográficos como documento independiente. Las menciones al cifrado en las PSI_XYZ_v1.1_May2024.docx son instrucciones operativas del tipo 'activa BitLocker en tu portátil', no una política normativa que defina el marco: no se especifican algoritmos mínimos aceptados (AES-256 para BitLocker, TLS 1.2 o superior para comunicaciones web), no se establece qué información debe cifrarse obligatoriamente más allá de los dispositivos, y el marco legal —Ley de Firma Electrónica, RGPD para datos en tránsito— no está abordado.

Segundo, y más urgente: aunque la política exige BitLocker en todos los portátiles, durante la auditoría se detectó que no hay evidencia de que el cifrado esté activo en los equipos del personal que teletrabaja fuera de la red corporativa. La verificación se realizó sobre tres equipos presentes en la oficina, pero para los portátiles asignados a los teletrabajadores no existe ningún inventario ni herramienta de gestión que acredite el estado de cifrado de cada dispositivo. A esto se añade que las claves de recuperación de BitLocker de todos los equipos están almacenadas en un Excel en la carpeta compartida de IT del servidor cloud, accesible por cualquier persona con acceso a esa carpeta. Si esa clave cae en manos equivocadas —y el servidor cloud no requiere MFA para acceder desde fuera de la red, según confirmó Juan Pérez— el cifrado deja de ser una salvaguarda.

Control auditado	A10.1.1 — Política de uso de los controles criptográficos
Evidencias revisadas	PSI_XYZ_v1.1_May2024.docx; verificación de BitLocker en 3 equipos presentes en oficina; revisión de ubicación de claves de recuperación en servidor cloud (carpeta compartida IT sin control de acceso específico); confirmación de ausencia de inventario de estado de cifrado en portátiles de teletrabajadores
Técnicas de verificación	Solicitud de política criptográfica formal, verificación técnica de BitLocker, comprobación de permisos de la carpeta de claves, entrevista con Juan Pérez sobre gestión de claves y cobertura de teletrabajadores

Nivel de madurez **Inicial**	BitLocker y VPN aplicados en la práctica, pero sin política formal de controles criptográficos. Sin inventario de estado de cifrado en portátiles de teletrabajadores. Claves de recuperación almacenadas en carpeta compartida sin control de acceso específico.

c) Conclusiones

NC MENOR NC-A-02	No existe política formal de controles criptográficos. No hay evidencia de que BitLocker esté activo en los portátiles del personal en teletrabajo (ausencia de

	inventario de estado de cifrado por dispositivo). Las claves de recuperación de BitLocker están almacenadas en una carpeta compartida del servidor cloud sin control de acceso específico, lo que anula parcialmente la protección que aporta el cifrado. Acciones correctivas: (1) Marta López debe redactar la política de controles criptográficos con casos de aplicación, algoritmos mínimos (AES-256, TLS 1.2+) y proceso de gestión de claves. (2) Juan Pérez debe implementar un inventario de estado de cifrado por dispositivo e incluir los equipos de teletrabajadores. (3) Reubicar las claves de recuperación de BitLocker en un repositorio seguro con acceso restringido y auditado (Azure AD o gestor de contraseñas corporativo). Plazo: 45 días.

3.4 Control A11.1.3 — Seguridad de oficinas, despachos y recursos

a) Comprensión del control

ISO 27002 exige que se diseñen y apliquen medidas de seguridad física para oficinas y recursos de forma proporcional a los riesgos identificados y a la sensibilidad de los activos que se almacenan o procesan en esas ubicaciones. La seguridad física no es accesoria: un servidor mal protegido físicamente puede comprometerse sin que ningún control lógico sirva de nada.

- ¿El CPD dispone de controles físicos proporcionales al valor de los activos que aloja (separación ignifugada, extinción automática, control de acceso electrónico con registro, sensores ambientales)?
- ¿Se cumplen en la práctica las políticas de clean desk y gestión de documentos sensibles?

b) Evaluación y evidencias

La sede de XYZ S.L. ocupa una planta de un edificio de alquiler con servicio de seguridad privada gestionado por el propietario del inmueble. El acceso al edificio está controlado por un vigilante en horario de oficina (lunes a viernes, 8:00-20:00), y el acceso a la planta requiere tarjeta de proximidad corporativa. Son controles básicos pero funcionales para una empresa de este tamaño.

El CPD es una historia diferente. El Informe_AR_XYZ ya lo señalaba explícitamente como vulnerabilidad en la sección de inventario de ubicaciones (U2), y la inspección física lo confirma y lo

empeora. El CPD está separado de la zona de oficinas por un tabique de pladur sin material ignifugante, con una puerta estándar con cerradura de palanca convencional. Llamó la atención durante la visita que en la base del bastidor del rack de comunicaciones hay marcas de humedad: la fotocopiadora que hay en la sala contigua descarga calor y condensación en la pared compartida, y esa humedad está llegando al rack. No es óxido todavía, pero está en camino de serlo si nadie lo corrige. No hay sistema de extinción automática. No hay sensores de temperatura ni de humedad con alerta. No hay control de acceso electrónico que registre entradas y salidas: el acceso está restringido de facto a Marcos y Ana, porque son los únicos que saben qué hay dentro, pero esa restricción no existe en ningún log ni en ningún sistema.

En la zona de administración, al final de la jornada del día 4 de marzo se encontraron sobre varias mesas albaranes y listados de rutas con nombres y direcciones de clientes. La política de clean desk en las PSI_XYZ_v1.1_May2024.docx es explícita. Que esto ocurra no significa que la política sea mala: significa que no se verifica su cumplimiento.

Control auditado	A11.1.3 — Seguridad de oficinas, despachos y recursos
Evidencias revisadas	Inspección física de la sede y el CPD (4 de marzo de 2026, al cierre de jornada); Informe_AR_XYZ_v1.0_Mar2026.docx (sección de inventario de ubicaciones U2); entrevista con Juan Pérez
Técnicas de verificación	Visita física a instalaciones al final de la jornada, verificación de controles de acceso al CPD, inspección del estado físico del rack, comprobación del cumplimiento de clean desk

Nivel de madurez **Inicial**	Controles básicos de acceso al edificio presentes. CPD con deficiencias físicas significativas: separación de pladur sin ignifugar, marcas de humedad en base del rack, sin extinción automática, sin control de acceso electrónico con registro, sin sensores ambientales. Incumplimiento de política de clean desk observado.

c) Conclusiones

NC MENOR NC-A-03	El CPD presenta deficiencias físicas significativas respecto a los activos críticos que aloja: tabique de pladur sin ignifugar, ausencia de extinción automática de incendios, sin control de acceso electrónico con registro de entradas y salidas, y humedad incipiente en la base del rack de comunicaciones por condensación de la fotocopiadora adyacente. No existe log de quién accede al CPD ni cuándo. Se incumple la política de clean desk en la zona de administración. Acciones correctivas: (1) Juan Pérez debe solicitar a la propiedad del edificio una revisión del sellado de la pared entre la sala de la fotocopiadora y el CPD, y evaluar la instalación de una bandeja de absorción de humedad. (2) Instalar control de acceso electrónico con registro en la puerta del CPD. (3) Instalar sensores de temperatura y humedad con alerta automática. (4) Marta López debe establecer verificaciones periódicas (mínimo semanales) de cumplimiento de clean desk.

3.5 Control A12.4.1 — Registro y gestión de eventos de actividad

a) Comprensión del control

ISO 27002 exige que se generen, mantengan y revisen periódicamente los registros de eventos de actividad de usuarios, excepciones, fallos y eventos de seguridad. Los logs son la memoria del sistema: sin ellos, cuando ocurre un incidente es imposible determinar qué pasó, cuándo, desde dónde y quién. Un sistema de logs que solo se consulta cuando ya ha ocurrido algo es un control reactivo, no preventivo.

- ¿Existe una política formal de gestión de eventos de seguridad con períodos de retención definidos?
- ¿Los sistemas clave (AD, ERP, Microsoft 365, FortiGate) generan logs con cobertura y retención suficientes?
- ¿Se revisan los logs periódicamente de forma proactiva? ¿Están protegidos contra manipulación?

b) Evaluación y evidencias

El Active Directory genera logs de inicio de sesión y cambios de contraseña por configuración predeterminada de Windows Server. El ERP SAP Business One genera logs de actividad de usuario. Son puntos de partida positivos. El problema empieza cuando se pregunta qué se hace con esos logs.

Tras entrevistar a Juan Pérez, este admitió sin rodeos que los logs se almacenan 'por si pasa algo', pero reconoció que nunca se han revisado de forma proactiva por falta de tiempo. Sus palabras exactas fueron: 'Si hay un incidente vamos a mirar, pero revisarlos de forma rutinaria... no tenemos capacidad para eso ahora mismo'. Eso confirma que el control es puramente reactivo y no preventivo. A eso se añade que la retención de logs del AD está configurada en siete días, el valor predeterminado de Windows Server: en la mayoría de los incidentes de seguridad reales, la detección no se produce en siete días. Los logs de Microsoft 365 están accesibles desde el portal de administración pero no se descargan ni se almacenan localmente; si Microsoft cambia sus condiciones de retención o si la suscripción se interrumpe, esos logs desaparecen. El FortiGate 60F genera logs de firewall, pero tampoco hay proceso de revisión documentado.

No existe SIEM ni herramienta de centralización de logs. Los administradores —Marcos cuando está disponible— podrían modificar los logs del AD sin que quedara ninguna traza de esa modificación. En una investigación forense posterior a un incidente, eso hace que los logs no sean fiables como evidencia.

Control auditado	A12.4.1 — Registro y gestión de eventos de actividad
Evidencias revisadas	Configuración de retención de logs del AD (7 días, valor predeterminado); logs del ERP SAP Business One; portal Microsoft 365 Admin Center; entrevista con Juan Pérez (IT)
Técnicas de verificación	Verificación de la configuración de retención del AD, revisión de logs del ERP, entrevista sobre frecuencia de revisión y proceso de gestión de eventos, comprobación de protección de integridad de logs

Nivel de madurez **Inicial**	Los sistemas clave generan logs por configuración predeterminada. Retención del AD insuficiente (7 días). Los logs no se revisan periódicamente por falta de recursos humanos —factor confirmado por el Responsable IT—. Sin SIEM ni centralización. Sin protección de integridad.

c) Conclusiones

NC MENOR NC-A-04	No existe política de gestión de eventos de seguridad. La retención de logs del AD es de 7 días (insuficiente para la mayoría de escenarios de detección de incidentes). Los logs nunca se revisan de forma proactiva, por reconocimiento explícito del Responsable IT, lo que convierte el control en puramente reactivo. No hay sistema de centralización ni protección de integridad. Acciones correctivas: (1) Juan Pérez debe ampliar la retención de logs del AD a un mínimo de 90 días mediante GPO y configurar el reenvío a un repositorio de solo lectura. (2) Marta López debe redactar la política de gestión de eventos de seguridad con periodicidad de revisión (mínimo mensual), responsable y criterios de alerta. (3) Evaluar e implantar una solución de centralización de logs o SIEM ligero, considerando las opciones disponibles en Microsoft 365 (Sentinel o Defender for Business). Plazo: 60 días.

3.6 Control A13.1.3 — Segregación en redes

a) Comprensión del control

ISO 27002 exige que los grupos de servicios de información, usuarios y sistemas estén separados en redes distintas, de forma que se limite la propagación de un incidente entre segmentos y se proteja la información sensible de accesos no autorizados desde otras zonas de la red. El objetivo es el radio de impacto: si un equipo se compromete, que no pueda alcanzar directamente los servidores críticos.

- ¿Existe una arquitectura de red segmentada mediante VLANs que separe al menos: CPD/servidores, puestos de trabajo de administración y dispositivos del almacén?
- ¿Está documentada la arquitectura de red con un diagrama actualizado?
- ¿La red Wi-Fi de invitados está correctamente segregada de la red corporativa?

b) Evaluación y evidencias

Se solicitó el diagrama de red actualizado de XYZ S.L. Juan Pérez facilitó un listado de rangos IP y una descripción verbal de la arquitectura, pero no existe ningún diagrama formal actualizado. Eso ya es en sí mismo una señal de que la red ha crecido de forma orgánica sin una arquitectura documentada.

Lo que se observó en la inspección es que XYZ S.L. tiene dos SSIDs Wi-Fi diferenciados: red corporativa con autenticación por credenciales de dominio y red de invitados/visitas. Esta separación está bien implementada y es apropiada para el contexto. Hasta ahí, las buenas noticias.

Lo que resulta preocupante es la ausencia total de segmentación en la red cableada interna. El CPD —con el servidor HP ProLiant que aloja el ERP, la base de datos con los datos de 3.200 clientes, el Active Directory y el NAS con síntomas de degradación— comparte el mismo segmento de red plana con los puestos de trabajo de administración y con los dispositivos del almacén (terminales de mano, ordenadores de logística). No hay VLANs que separen la red de servidores de la red de usuario ni la red del almacén de la red de administración. Un equipo comprometido en el almacén tiene acceso directo de red al ERP y a la base de datos, sin que ningún firewall interno ni ACL lo impida. La verificación técnica de conectividad entre segmentos lo confirmó.

A pesar de lo manifestado por el equipo de IT respecto a que 'la segmentación está en el roadmap del PDS', la situación actual no cumple el control A13.1.3.

Control auditado	A13.1.3 — Segregación en redes
Evidencias revisadas	Listado de rangos IP facilitado por Juan Pérez; verificación de los dos SSIDs Wi-Fi (corporativa e invitados); prueba de conectividad entre segmento almacén y servidor CPD; diagrama de red formal (no disponible)
Técnicas de verificación	Solicitud de diagrama de red actualizado, verificación de configuración del controlador Wi-Fi, prueba de conectividad entre segmentos de red, entrevista con Responsable IT sobre arquitectura de red

Nivel de madurez **Repetible**	Separación correcta entre red Wi-Fi corporativa e invitados. Sin segmentación interna mediante VLANs: la red del almacén, la red de administración y el CPD comparten el mismo segmento plano. Sin diagrama de red formal actualizado.

c) Conclusiones

NC MENOR NC-A-05	La red interna de XYZ S.L. es una red plana sin VLANs: el CPD (ERP, BBDD, AD, NAS) comparte segmento de red con los puestos de trabajo de administración y con los dispositivos del almacén. Un equipo comprometido en cualquier zona tiene acceso de red directa a los servidores críticos sin restricciones adicionales. La separación Wi-Fi corporativa/invitados es correcta. No existe diagrama de red formal actualizado. Acciones correctivas: (1) Juan Pérez debe diseñar e implementar una segmentación mínima de la red interna mediante VLANs: al menos VLAN de servidores (CPD), VLAN de puestos de administración y VLAN de almacén, con el FortiGate 60F como firewall interno entre ellas. (2) Elaborar y mantener actualizado el diagrama de red formal. Plazo: año 1 del PDS (2026), conforme al hallazgo T1.

3.7 Control A17.1.1 — Planificación de la continuidad de la seguridad de la información

a) Comprensión del control

ISO 27002 exige que la organización determine sus requisitos de seguridad de la información y continuidad de la gestión en situaciones adversas, y planifique cómo alcanzarlos. No basta con tener un plan de respuesta ante incidentes cibernéticos: la continuidad debe cubrir también contingencias físicas, como un incendio en el CPD, un fallo eléctrico prolongado o la indisponibilidad de proveedores críticos.

- ¿Existe un Plan de Continuidad de Negocio (PCN) completo que cubra contingencias físicas y de infraestructura, además de incidentes cibernéticos?
- ¿Se han realizado simulacros o pruebas de recuperación que acrediten la viabilidad del plan?

b) Evaluación y evidencias

El PRI_XYZ_v1.0_Mar2026.docx es un documento sólido para la respuesta ante incidentes de ciberseguridad: define escenarios (con el ransomware sobre el ERP como principal), equipos de gestión, estrategia de comunicación y procedimientos de contención, erradicación y recuperación. El Informe_AR_XYZ incluye un BIA en su sección 4 con activos críticos y tiempos de recuperación deseados. Es una base real.

Pero el PRI no es un PCN. Cubre bien el escenario de ransomware, pero no aborda qué hace XYZ S.L. si hay un incendio en el CPD, si el suministro eléctrico falla durante más horas de lo que aguanta el SAI —cuya batería está degradada— o si el único proveedor de fibra tiene una avería. El corte de octubre, que el propio CEO citó como detonante de este proceso, duró cuatro horas y no fue un incidente de ciberseguridad: fue un corte eléctrico por obras en la calle. Ese escenario no está cubierto por el PRI. El PDS prevé el Plan de Continuidad TIC como proyecto del año 3 (2028), lo que significa que XYZ S.L. llegará a la auditoría de certificación sin tenerlo.

Llamó la atención que, según Juan Pérez, los backups no han sido testados con una restauración real desde hace más de un año. El Plan de Respuesta ante Incidentes asume en su sección 4.5 que los backups son funcionales y recientes. Si esa suposición no es cierta cuando se necesitan, el plan no es ejecutable.

Control auditado	A17.1.1 — Planificación de la continuidad de la seguridad de la información
Evidencias revisadas	PRI_XYZ_v1.0_Mar2026.docx; Informe_AR_XYZ_v1.0_Mar2026.docx (sección 4, BIA); PDS_XYZ_v1.0.docx (proyecto Plan Continuidad TIC — año 3); evidencia de simulacros y pruebas de restauración (no disponible)
Técnicas de verificación	Solicitud del PCN, revisión del PRI, verificación de pruebas de recuperación recientes, entrevista con Juan Pérez sobre estado de los backups y último test de restauración

Nivel de madurez **Inicial**	PRI sólido para incidentes de ciberseguridad y BIA en el análisis de riesgos. Sin PCN completo que cubra contingencias físicas. Sin simulacros documentados ni pruebas de restauración de backups en los últimos 12 meses.

c) Conclusiones

OBSERVACION OBS-A-02	El Plan de Respuesta ante Incidentes es una base sólida para continuidad ante incidentes de ciberseguridad, pero no cubre contingencias físicas (incendio en CPD, fallo eléctrico prolongado, indisponibilidad del proveedor de fibra). No se han realizado simulacros ni pruebas de restauración de backups en los últimos 12 meses. Se recomienda adelantar el Plan de Continuidad TIC del año 3 del PDS o, al menos, elaborar un documento de continuidad mínimo que cubra los escenarios físicos antes de la auditoría de certificación, y planificar un test de restauración de backups con carácter urgente. Si en la siguiente revisión no se ha subsanado, pasará a no conformidad menor.

3.8 Control A18.1.2 — Derechos de Propiedad Intelectual (DPI)

a) Comprensión del control

ISO 27002 exige que la organización implemente procedimientos que garanticen el cumplimiento de los requisitos legales, contractuales y regulatorios relacionados con los derechos de propiedad intelectual y el uso de software propietario. La evidencia técnica clave es la existencia de un inventario de software instalado con sus correspondientes licencias acreditadas: sin inventario, no hay forma de demostrar cumplimiento ni de detectar software sin licencia. El incumplimiento de la Ley de Propiedad Intelectual (Real Decreto Legislativo 1/1996) no es solo una multa administrativa: puede derivar en responsabilidad penal para los miembros de la gerencia que conocieran o debieran conocer la situación.

- ¿Existe un inventario formal y actualizado de todo el software instalado en los equipos de XYZ S.L., con las licencias asociadas verificadas?
- ¿Se realizan comprobaciones periódicas del estado de activación del software instalado?
- ¿Hay un proceso formal de aprobación y adquisición de licencias para nuevas instalaciones?

b) Evaluación y evidencias

Las PSI_XYZ_v1.1_May2024.docx establecen la prohibición de instalar software no autorizado y los usuarios no tienen permisos de administrador local en sus equipos, lo que limita técnicamente las instalaciones no controladas. Son controles preventivos razonables. Sin embargo, no existe ningún inventario formal de software instalado con sus licencias asociadas. Cuando se solicitó durante la

auditoría, Juan Pérez respondió que 'lo tiene más o menos en la cabeza, pero no está documentado en ningún sitio'.

La inspección técnica por muestreo de cinco portátiles corporativos seleccionados al azar arrojó un resultado que va más allá de una no conformidad menor. En dos de los cinco equipos, al abrir Microsoft Office, apareció la ventana de activación de producto: las licencias no están activas. En un tercer equipo se encontró WinRAR instalado sin licencia comercial (el uso empresarial requiere licencia de pago; la pantalla de aviso apareció al abrirlo). En un cuarto equipo, el sistema operativo Windows 10 mostraba la marca de agua de 'Activar Windows' en el escritorio. Cuatro de cinco equipos con software sin licencia válida es una muestra suficientemente representativa para concluir que el problema es sistémico, no puntual.

Aunque se nos mostró una hoja de Excel con algunas claves de producto, no pudimos verificar si cubre todos los equipos ni si incluye los portátiles del personal en teletrabajo, por lo que no puede considerarse el inventario de software legalizado que exige el control.

Control auditado	A18.1.2 — Derechos de Propiedad Intelectual (DPI)
Evidencias revisadas	PSI_XYZ_v1.1_May2024.docx; inspección técnica de 5 portátiles corporativos (muestreo); hoja Excel con algunas claves de producto (incompleta, sin cobertura verificable de todos los equipos); ausencia de inventario formal de software legalizado
Técnicas de verificación	Inspección técnica de equipos con verificación de estado de activación de SO y software de productividad, solicitud de inventario de licencias, entrevista con Juan Pérez sobre proceso de gestión de licencias

Nivel de madurez **Inicial**	Controles preventivos básicos (prohibición en política, sin permisos de admin local). Sin inventario formal de software legalizado. Cuatro de cinco equipos inspeccionados con software sin licencia activa, lo que indica un problema sistémico.

c) Conclusiones

NC MAYOR NC-A-06 · NO CONFORMIDAD MAYOR	La inspección técnica detectó software sin licencia válida en 4 de los 5 equipos inspeccionados: dos instancias de Microsoft Office sin activar, un WinRAR sin licencia comercial y un Windows 10 sin activar. No existe inventario formal de software instalado con licencias asociadas verificadas. El incumplimiento del Real Decreto Legislativo 1/1996 (Ley de Propiedad Intelectual) puede derivar en responsabilidad penal directa para los miembros de la gerencia. Este hallazgo es, por sí solo, causa de denegación de la certificación ISO 27001. Acciones correctivas: (1) Juan Pérez debe inventariar de forma urgente todo el software instalado en todos los equipos —incluidos los de teletrabajadores— en un plazo máximo de 15 días. (2) Marta López debe coordinar con Gerencia la regularización de todas las licencias en un plazo máximo de 30 días. (3) Implantar una herramienta de gestión de activos de software (SAM) que permita monitorizar el estado de licencias de forma continua. (4) Establecer un proceso formal de aprobación y adquisición de licencias para nuevas instalaciones.

4. Resumen de hallazgos

La siguiente tabla consolida todos los hallazgos identificados durante la auditoría, con su clasificación y nivel de madurez asignado.

Ref.	Control auditado	Hallazgo	Nivel de madurez
4.1	Comprensión de la organización y su contexto	**NC Menor**	Inicial
8.3	Tratamiento de los riesgos de seguridad	**NC Menor**	Definido
9.1	Seguimiento, medición, análisis y evaluación	**NC Mayor (Métricas)**	Inicial
9.2	Auditorías internas	**NC Menor**	Inexistente
A5.1.1	Políticas para la seguridad de la información	**Conforme + Observacion**	Administrado
A9.4.3	Sistema de gestión de contraseñas de usuario	**NC Menor**	Inicial
A10.1.1	Política de controles criptográficos	**NC Menor**	Inicial
A11.1.3	Seguridad de oficinas, despachos y recursos	**NC Menor**	Inicial
A12.4.1	Registro y gestión de eventos de actividad	**NC Menor**	Inicial
A13.1.3	Segregación en redes	**NC Menor**	Repetible
A17.1.1	Planificación de continuidad de la seguridad	**Observacion**	Inicial

Ref.	Control auditado	Hallazgo	Nivel de madurez
A18.1.2	Derechos de Propiedad Intelectual	**NC Mayor (DPI)**	Inicial

Consolidado de hallazgos: 2 no conformidades mayores (NC-R-03, NC-A-06) · 6 no conformidades menores (NC-R-01, NC-R-02, NC-R-04, NC-A-01, NC-A-02, NC-A-03, NC-A-04, NC-A-05) · 3 observaciones (OBS-A-01, OBS-A-02) · 1 hallazgo conforme con observación (CONF-A-01 + OBS-A-01)

5. Conclusiones y recomendaciones

XYZ S.L. está en proceso de construir su SGSI desde una base razonablemente sólida. La nueva gerencia ha demostrado compromiso real con la seguridad: las políticas están aprobadas formalmente, el análisis de riesgos tiene metodología rigurosa, el Plan Director de Seguridad tiene horizonte trianual y el Plan de Respuesta ante Incidentes es técnicamente competente. Eso no es lo habitual en una organización de 60 empleados que acaba de iniciar este camino.

Lo que esta auditoría pone de manifiesto es que la distancia entre lo planificado y lo implantado es todavía significativa. El SGSI existe en los documentos, pero no siempre en la práctica cotidiana. Las contraseñas siguen acabando en post-its. El AD no fuerza su cambio periódico. Los logs se guardan 'por si pasa algo' pero nadie los revisa. El CPD está separado de la oficina por un tabique de pladur que tiene marcas de humedad en la base del rack. El software sin licencia en cuatro de cinco equipos inspeccionados no es descuido puntual: es la consecuencia de no tener un inventario. El gap entre lo planificado y lo efectivo es exactamente lo que este proceso de certificación debe cerrar.

Las dos no conformidades mayores requieren atención prioritaria e inmediata. NC-R-03 (ausencia de sistema de métricas operativo) y NC-A-06 (software sin licencia, con riesgo de responsabilidad penal para la gerencia) son causas directas e independientes de denegación de la certificación. No admiten posposición.

Las seis no conformidades menores y las tres observaciones son subsanables antes de la auditoría de certificación, pero requieren un Plan de Acciones Correctivas (PAC) con responsables, plazos y evidencias de cierre. Se recomienda que Marta López (CISO) coordine la elaboración de ese PAC en las próximas dos semanas, con revisión mensual del estado de cierre.

Con la resolución de los hallazgos identificados y la continuación del proceso de madurez conforme al PDS 2026-2028, XYZ S.L. está en condiciones de afrontar una auditoría de certificación con garantías razonables de éxito en el segundo semestre de 2027.

Auditora	Revisado por CISO	Fecha
Begoña Rodríguez Arteaga	Marta López	4 de marzo de 2026
Firma: _____	Firma: _____	